

소프트웨어개발보안경진대회 개발기획서

지원트랙	☐ 트랙 A : 자유주제 부문 ☐ 트랙 B : 기술혁신 부문 ☒ 트랙 C : 공공활용 부문		
팀명	SafeTrace	개발언어	Python
프로젝트명	SafeTrace — AI 기반 위협 의심 사이트 자율 후보 발굴·증거화·공공심의 지원 시스템		
프로젝트 소개	공공데이터(KISA 피싱사이트 URL)·신고 URL 에서 출발해 관찰된 링크·리다이렉트를 따라 위협 의심 사이트를 자율 발굴하고, 격리 브라우저로 동적 증거를 수집·보존한 뒤 AI 분석 의견과 함께 공공기관 검토 패키지로 자동 생성한다. 최종 판정은 담당자가 한다.		
팀 소개 및 팀원별 역할	2 인 팀. 팀원 1: 자율 후보 발굴·Browser Agent·백엔드·증거 체인 / 팀원 2: AI 분석 모델·판정 콘솔·실시간 UI·평가 / 공통: 위협 모델링, CI 보안 점검, 교차 리뷰		

한눈에 보기

- 핵심 구조: ① 자율 후보 발굴(Candidate Discovery) → ① 자체 Browser Agent → ② 자체 AI Decision Engine → ③ 공공기관 검토 패키지 자동 생성
- 자율 발굴(핵심 기능): 공공데이터포털 KISA 피싱사이트 URL·신고 URL·공식 검색 API 결과 → 후보 큐 → 중복·범위·안전 검사 → 우선순위 선정 → Browser Agent → 관찰된 후속 후보 재큐잉
- 사전 구현: 브라우저 렌더링 녹화·실시간 조사 화면, AI 분석 의견 생성, Safe Browsing 조회, 공개 정상 사이트 평가 자료(D3) 구현 완료. 본선에서는 발굴 엔진·증거 체인·보안 통제를 통합
- 안전 경계: 인터넷 전체 무차별 크롤링·DNS 대입 탐색·인증 우회는 제외하고 허용된 공개 소스와 관찰된 연결 관계만 제한적으로 확장

- 보안 설계: 조사 Worker 전용 네트워크와 egress 프록시(SSRF 이중 방어), 증거 해시 체인과 분리 키 HMAC 서명
- 주 활용처: 공공기관의 신고·심의·사실 확인 업무. 실제 기관 적용 전에는 기관별 법적 근거·절차·보안성 검토가 필요

1 추진 배경 및 필요성 (작성비중 : 20%)

1.1 문제 상황

피싱·사기·불법 도박 등 웹 기반 유해 행위는 URL 을 바꾸거나 여러 단계의 리다이렉트를 거치고, 페이지 렌더링 후에야 결제·입금·개인정보 입력 요소를 노출하는 방식으로 탐지를 회피한다. URL 문자열이나 최초 HTML 만 보는 정적 분석은 실제 사용자가 보게 되는 화면과 이동 경로를 놓칠 수 있다.

공공기관의 신고·심의 업무에서는 의심 URL 을 직접 열어 사실관계를 확인하고, 화면·이동 경로·표시 문구·입력 폼 등을 캡처해 사건 자료로 정리해야 한다. 이 과정은 반복적이며, 조사자가 위험 페이지를 직접 접촉한다는 안전 문제와 수집 시각·원본성·변경 이력을 설명해야 하는 증거 관리 문제가 동시에 발생한다.

공공 현업 필요성 근거 ① 한국인터넷진흥원(KISA)이 2026 년 2 월 공개한 2023~2025 년 스미싱 대응 현황에서는 정부·공공기관 사칭 유형이 약 214 만 건(53.4%)으로 가장 큰 비중을 차지했다. 이는 공공기관의 명칭·서비스를 악용한 URL 기반 위협이 반복·대량 발생하고 있어, 신고·확인·대응 과정에서 의심 URL 을 안전하고 일관되게 분석할 필요가 크다는 점을 보여준다. (출처: KISA 보호나라, 「설 명절 연휴기간 스미싱, 피싱 등 사이버 사기 주의」, 2026.2.12.)

공공 현업 필요성 근거 ② KISA 는 2025 년 4 월 보안공지에서 '유심 무상 교체' 등의 검색 결과에 노출된 사이트가 비영리 도메인을 경유해 도박 사이트로 연결되는 사례를

확인했다. 이는 최초 URL 이나 정적 HTML 만으로는 실제 최종 화면과 이동 경로를 충분히 파악하기 어려운 리다이렉트 기반 위협이 현실에서 관찰되고 있음을 보여주며, SafeTrace 가 격리 브라우저에서 렌더링·리다이렉트·최종 목적지를 증거로 기록해야 하는 필요성을 뒷받침한다. (출처: KISA 보호나라, 「유심 무료 교환, 유심보호서비스 등 사회적 이슈 관련 피싱·스미싱 공격 주의」, 2025.4.27.)

공공 현업 필요성 근거 ③ 경찰청 경찰민원 24 는 해킹·사기·불법 사이트를 사이버범죄 제보 대상으로 명시하고, '온라인 접수 → 경찰청 검토 → 조사 착수 → 종결' 절차와 증거자료 제출을 안내한다. 이는 실제 공공기관이 불법 사이트 신고와 증거자료를 검토해 후속 조사로 연결하는 업무를 수행함을 보여주며, SafeTrace 의 'URL 접수 → 증거 수집·정리 → 담당자 검토' 흐름과 직접 맞닿아 있다. (출처: 경찰청 경찰민원 24, 「사이버범죄 제보하기」, 2026.9.24. 조회.)

또한 단일 "악성 점수"만 제시하는 자동화는 공공 업무에 그대로 적용하기 어렵다. AI 가 높은 확률을 출력하더라도 그것은 법적 위법성의 확률이 아니며, 담당자는 어떤 사실과 증거가 그 분석으로 이어졌는지 확인할 수 있어야 한다. 따라서 공공 활용 시스템의 핵심은 자동 판정이 아니라 "안전하게 수집된 사실 → 설명 가능한 AI 분석 → 사람이 검토 가능한 사건 패키지"의 연결이다.

1.2 기존 서비스와의 비교 및 차별점

비교 대상	제공 기능	공공 심의 업무 관점의 한계
담당자 수동 조사	업무 PC 브라우저로 직접 접속·캡처한 뒤 문서로 정리	조사자가 위험 페이지에 직접 노출되고, 다단계 리다이렉트·지연 렌더링을 놓치기 쉬우며, 수집 시각·원본성을 증명하기 어려움
urlscan.io	샌드박스 브라우저 렌더링, 스크린샷·DOM·네트워크	해외 서비스로 URL 과 결과가 전송되어 공개 범위 관리가 필요. 사건 단위 증거

	요청·리다이렉트 기록	무결성·담당자 판정 기록·감사로그와 연관 후보 자동 발굴은 제공하지 않음
VirusTotal (URL 검사)	다수 보안 엔진의 평판 판정 집계	엔진별 판정 집계 중심이라 판단 근거가 화면 증거로 이어지지 않음. 제출 URL 이 보안 커뮤니티와 공유될 수 있어 사건 정보 관리에 부담
Google Safe Browsing	알려진 위협 목록 등재 여부 조회	신규·미등재 사이트는 결과가 없고, 등재 사유나 화면 증거를 제공하지 않음
보호나라 스미싱· 피싱 확인서비 스	국민이 카카오톡 채널로 의심 문자·URL 을 신고하고 악성 여부를 확인	대국민 신고·확인 창구로, 접수 이후 담당자의 사건 단위 증거 정리·심의 기록은 별도 업무로 남음. SafeTrace 는 이 뒤 단계를 보조하는 보완 관계
SafeTrace (차별점)	관찰 관계 기반 후보 자율 발굴 + 격리 렌더링 동적 증거 + evidence_id 가 연결된 AI 분석 의견 + 공공기관 검토 패키지	증거마다 SHA-256·해시 체인·분리 키 HMAC 서명·감사로그, AI 판정 권한 배제와 담당자 확정, 기관 내부 배치 가능(Safe Browsing 조회 외 외부 제출 없음)

1.3 독자적 접근법

- 후보 발굴·브라우저 관찰·AI 분석을 분리한다. 자율 후보 발굴 엔진은 KISA
피싱사이트 URL·신고 URL·공식 검색 API 결과를 시작점으로 후보를 큐에 넣고
관찰된 링크·리다이렉트를 따라 후보를 스스로 확장한다. Browser Agent 는 사실만
수집하며 AI Decision Engine 은 그 사실을 유형별로 해석한다.
- AI 출력은 반드시 증거 ID 와 연결한다. 예: “피싱 의심 0.82”만 보여주는 것이 아니라

어떤 화면 문구·폼 구조·도메인 관계가 영향을 주었는지 함께 제시한다.

1.4 개발 목표

- ① 자율 후보 발굴·증거화: KISA 피싱사이트 URL·신고 URL·공식 검색 API 결과에서 후보를 수집·우선순위화하고, 격리 Browser Agent 가 조사하며 관찰된 후속 후보를 관계 그래프 기반으로 다시 큐에 넣어 제한적으로 탐색을 이어간다. 수집한 동적 증거는 무결성을 보존한다.
- ② 자체 AI 분석: 수집된 구조화 데이터를 기반으로 유해 의심 유형과 AI 신뢰도, 근거를 생성하되 불확실성을 명시하고 판정을 확정하지 않는다.
- ③ 공공기관 활용: AI 결과와 증거, Safe Browsing 조회 결과를 담당자 검토용 사건 패키지와 보고서 초안으로 자동 가공한다.
- ④ 개발보안: 공격자가 통제하는 웹 콘텐츠를 다루는 시스템 자체를 STRIDE 위협 모델링과 행정안전부 SW 보안약점 기준에 맞춰 시큐어코딩한다.
- ⑤ 3 주 핵심 완성: 개발경연 시작 후 3 주 안에 자율 발굴을 포함한 ①→②→③ 핵심 흐름과 평가용 데이터·보안 시험을 완성하고, 잔여 기간은 공지 미션과 개선에 사용한다.

2 주요 기능 및 개발환경 (작성비중 : 50%)

2.1 최종 시스템 구성: ① 자율 후보 발굴 → ② 조사 → ③ 분석 → ④ 검토 패키지

SafeTrace 최종 아키텍처

① 자율 후보 발굴 → ② 조사 → ③ 분석 → ④ 검토 패키지



그림 1. SafeTrace 최종 아키텍처

처리 흐름과 안전 경계

공개 소스에서 시작해 관계 그래프를 따라 후보를 자율 발굴



그림 2. 처리 흐름과 안전 경계

2.2 ① 자체 Browser Agent — 안전한 동적 관찰과 후보 추적

Browser Agent 는 우선순위가 부여된 후보 URL 을 격리 Chromium 에서 실제 렌더링하고, AI 가 판단할 수 있는 구조화 입력과 검증 가능한 증거를 만든다. 관찰 대상은 화면 렌더링·지연 로딩·리다이렉트·일반 링크 이동이다.

기능	구현 방식	출력/통과 기준
Seed/후보 접수	공공데이터포털 KISA 피싱사이트 URL(CSV·오픈 API), 신고 URL·CSV, 공식 검색 API 결과. 출처·발견 시각 기록, URL 정규화·중복 제거	Candidate ID·원본/발견 출처·우선순위 생성
접근 전 검사	URL 정규화, DNS 확인, 사설·예약 IP 차단, 연결 시점 IP 재확인	SSRF/DNS Rebinding 유도 요청 차단
격리 렌더링	Playwright+Chromium, 비관리자 컨테이너, 시간·메모리 제한. 조사 Worker 는 내부 서비스와 분리된 전용 네트워크에서 실행되고 외부 접속은 egress 전용 프록시로만 가능	동적 화면·본문·DOM·폼 구조 확보
이동 경로 추적	HTTP/브라우저 리다이렉트 단계를 기록하고 각 단계 목적지를 재검사	최초/중간/최종 URL 과 상태 기록
자율 후보 발굴·재규 잉	공개 페이지의 링크·리다이렉트·스크립트/리소스 참조에서 연관 후보 추출. 정상 도메인 허용목록 제외 후 신규 등록·유사 도메인 가점으로 점수화하고 발견 경로·깊이와 함께 재규잉	허용목록 도메인 재규잉 0 건. 깊이·후보 수·시간·도메인 예산으로 무한 확장 방지

증거 보존	스크린샷·HTML 요약·DOM 특징·요청 메타데이터에 SHA-256·수집 시각·버전 부여. 레코드마다 직전 레코드 해시를 연결한 해시 체인과 분리된 서명 서비스의 HMAC 서명 기록	파일·해시 동시 변조를 포함한 변조 주입 시 100% 탐지 목표
안전 제한	다운로드, Service Worker, 팝업 자동 차단. 로그인·결제·폼 입력 금지	조사자·기관망 보호

공공데이터 활용: KISA 피싱사이트 URL 데이터는 KISA 가 실제 탐지한 URL 이므로 자율 발굴의 Seed 이자 URL·도메인 패턴 분석의 참조 데이터로 활용한다. 과거 탐지 URL 은 이미 접속되지 않는 경우가 많으므로 접속 불가(UNREACHABLE)를 별도 상태로 기록하고, 살아 있는 URL 과 그 도메인 관계를 우선 확장 대상으로 삼는다.

재큐잉 우선순위: 관찰된 링크를 그대로 재큐잉하지 않는다. 피싱 페이지는 사칭 대상인 실제 은행·기관 사이트로 링크를 거는 경우가 많으므로, 공공기관·금융기관 공식 도메인과 상위 인기 도메인(Tranco 목록)으로 만든 정상 도메인 허용목록은 재큐잉에서 제외하고 '사칭 대상' 관계로만 기록한다(사칭 대상 자체가 분석 증거가 됨). 나머지 후보는 신규 등록 도메인(RDAP 등록일), 사칭 대상과 닮은 유사 도메인(편집 거리·호모글리프·Punycode), 리다이렉트 체인의 경유 도메인, 개인정보·결제 입력 폼이 관찰된 페이지와의 연결에 가점을 주고, 공용 CDN·광고·분석 스크립트 도메인은 감점해 점수 상위 후보만 탐색 예산 안에서 조사한다.

검색 소스: Seed 중 검색 결과는 네이버 검색 API(웹문서 검색)의 공식 응답으로 한정한다. 검색어는 KISA·보호나라 주의보에 공개된 사칭 키워드(예: '유심 무상 교체')로 제한하고, API 이용약관과 일일 호출 한도(25,000 회) 안에서만 호출하며 검색 결과 페이지를 직접 스크래핑하지 않는다. 약관상 제약이 확인되면 이 소스만 제외하며, 핵심 흐름(KISA·신고 URL Seed)은 그대로 유지된다.

2.3 ② 자체 AI Decision Engine — 구조화 증거 기반 분석

AI Decision Engine 은 TypeSafe Jev(자유 문장 대신 미리 정의된 선택지 중 하나를 타입이 정해진 형태로 반환하는 TypeSafe 사의 구조화 의사결정 모델)의 "구조화 입력→제한된 선택지→신뢰도 출력" 방식을 참고하되, SafeTrace 의 증거 스키마와 공공기관 검토 흐름에 맞춰 로컬 환경에서 독자적으로 구현한다. Jev API 직접 연동은 수집 원문의 외부 전송을 수반하므로 후속 단계에서 검토한다. AI 는 "불법 여부"를 확정하지 않고, 웹페이지가 어떤 위협 유형과 유사한지 분석 의견을 제공한다.

입력 계층	예시 특징	AI 가 사용하는 방식
URL/도메인	호스트명 구조, 경로 패턴, 리다이렉트 관계, 신규 후보 간 연결	정형 특징 벡터
본문/화면	기관·브랜드 사칭 문구, 금전 요구, 충전·환전, 개인정보 요구 문구	텍스트 분류 입력
DOM/폼	password/tel/card 등 입력 필드 종류, submit 구조, 외부 전송 대상	구조 특징
네트워크	외부 도메인 수, 최종 목적지 변화, 추적 중 관찰된 요청 메타데이터	행동 특징
증거 참조	각 특징의 evidence_id, 수집 시각, 원본 해시	결과를 근거와 연결

AI 출력	정의	운영 원칙
threat_types	PHISHING, SCAM, ILLEGAL_GAMBLING_SUSPECTED, MALWARE, OTHER 복수 후보	법적 범죄유형 확정이 아닌 기술적 의심 범주
confidence	각 유형에 대한 모델 신뢰도 0~1	"불법 확률"로 표현하지 않음
evidence_lin	판단에 사용된 evidence_id	담당자가 원본 증거를 바로 확인

ks	목록과 짧은 근거	
review_state	REVIEW_REQUIRED / UNKNOWN	임계값 미달·증거 부족은 보류
model_meta	모델 버전·해시·추론 시각	재현성과 감사 가능성 확보

모델은 로컬 실행 가능한 다국어 분류 모델 또는 임베딩+분류 헤드로 시작하고, 학습 부담을 낮추기 위해 1 차 버전은 규칙 기반 특징과 제로샷·소량 학습 분류를 결합한다. AI 단독 정확도를 앞세우기보다 규칙 기준선과 비교하고, 신뢰도 보정·UNKNOWN 처리까지 포함해 안전한 의사결정 보조 도구로서 평가한다.

2.4 ③ 공공기관 검토 패키지 자동 생성 + Safe Browsing 조회

③ 단계는 Browser Agent 와 AI Decision Engine 의 결과를 기관 담당자가 바로 검토할 수 있는 사건 패키지로 자동 가공하는 단계이며, 외부 서비스로 자동 신고·제출하지 않는다. Google Safe Browsing 은 외부 평판을 조회하는 보조 신호로만 사용한다.

패키지 항목	자동 생성 내용
사건 개요	원본 URL, 출처, 접수 시각, 조사 시각, 최종 URL, 조사 상태
증거 묶음	스크린샷, 이동 경로, 화면/본문 요약, 폼·외부 요청 구조, 증거 해시
AI 분석	유형 후보, confidence, evidence_links, UNKNOWN/재검토 사유
외부 평판	Google Safe Browsing 조회 결과와 조회 시각. 미등재는 BENIGN 근거로 사용하지 않음
담당자 영역	검토 체크, 판정 상태, 판정 사유, 담당자·시각, 감사로그
보고서 초안	기관 제출 양식으로 옮기기 쉬운 요약본, PDF·JSON 내보내기

2.5 데이터 모델과 작업 파이프라인

객체	핵심 필드	목적
----	-------	----

Case	case_id, source, original_url, discovered_from, priority, depth, status, created_at	사건 원본·후보 출처/관계·우선순위 추적
Observation	final_url, redirect_chain, dom_summary, forms, request_summary	Browser Agent 관찰 결과
Evidence	evidence_id, type, object_path, sha256, prev_hash, hmac_sig, captured_at, version	증거 무결성
AIAnalysis	model_version, threat_types, confidence, evidence_links, state	재현 가능한 AI 분석
Reputation	provider, result, checked_at	Safe Browsing 등 조회 결과
Review	reviewer_id, decision, reason, decided_at	사람 최종 판단과 책임 추적
AuditLog	actor, action, target, timestamp, result	전체 변경 이력

PostgreSQL 을 상태의 원본으로 사용하고 Redis Streams 로 Candidate Discovery Queue → Browser Agent → AI Decision Engine → Package Builder 작업을 전달한다. 후보마다 출처·발견 경로·우선순위·깊이·처리 상태를 기록하며, visited 집합과 멍등 키로 중복·순환 탐색을 차단한다. 각 작업의 상태 전이는 사건 상태와 감사로그에 기록하고, 백엔드는 SSE(Server-Sent Events)로 프론트엔드에 후보 발견/큐잉/조사/분석/패키지 생성 이벤트를 전달해 단계별 상태와 후보 건수를 실시간 갱신한다. 아웃박스 패턴·재시도 정책으로 중간 실패를 통제한다.

2.6 개발환경

구성	기술	선택 이유
----	----	-------

Backend/API	Python 3.13+, FastAPI, Pydantic	비동기 I/O 와 명시적 스키마 검증
Browser Agent	Playwright + Chromium	동적 렌더링·요청 가로채기·재현 가능한 자동화
DB/Queue	PostgreSQL 18, Redis 8 Streams	상태 일관성, 재시도·작업 분리
AI Decision Engine	PyTorch/Transformers, 로컬 다국어 분류 모델	외부로 원문을 보내지 않고 버전 고정 가능
Frontend	React 19, TypeScript, Vite	실시간 파이프라인·후보 관계 그래프·발견/대기/조사/검토 건수·증거·AI 근거 검토 UI
Container	Docker Compose(internal 네트워크), egress 프록시	조사 Worker 전용 네트워크, 외부 접속은 프록시 단일 경로
Security CI	Semgrep, Bandit, pip-audit, npm audit, gitleaks	SAST·SCA·비밀 정보 검출 자동화

2.7 개발보안 설계

신뢰 경계와 주요 개발보안 통제

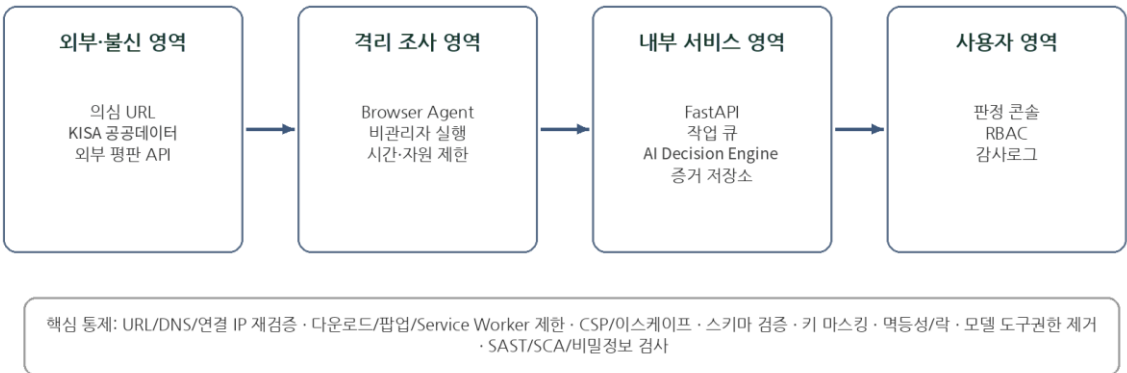


그림 3. SafeTrace 신뢰 경계와 개발보안 통제

SafeTrace 는 공격자가 만든 웹페이지를 직접 처리하므로 "수집된 모든 값은 불신 데이터"라는 원칙을 적용한다. 기능 구현보다 먼저 신뢰 경계를 정하고 각 경계별 위협을 시험 케이스로 만든다.

위협	발생 지점	대응
SSRF / DNS Rebinding	Browser Agent 가 리다이렉트·리소스를 따라갈 때	URL·DNS·연결 IP 단계별 재검증(1 차), egress 프록시의 목적지 차단과 Worker 전용 네트워크(2 차), 타임아웃
저장형 XSS	수집한 페이지 문구를 콘솔에서 표시	React 기본 이스케이프, CSP, raw HTML 렌더링 금지
프롬프트 인젝션	페이지에 AI 조작 문구 삽입	AI 입력을 데이터 필드로 격리, 도구 실행 권한 없음, 구조화 출력 스키마 강제
권한 우회/IDOR	사건·증거·판정 API	RBAC, 서버 측 객체 권한 검사, CSRF 보호
증거 변조	저장소 파일·해시 동시 수정(내부자 포함)	해시 체인, 저장소와 분리된 키의 HMAC 서명, TSA 타임스탬프, 조회 시 재검증, 추가 전용 감사로그
자원 고갈	무한 리다이렉트·대용량 DOM	사건별 시간/메모리/요청 수 제한, Worker 강제 종료
비밀 정보 노출	API 키·토큰·오류 로그	환경변수/시크릿 분리, 로그 마스킹, gitleaks
공급망 위험	Python/npm 패키지	lockfile 고정, SCA, 이미지/패키지 버전 고정

네트워크 격리: 조사 Worker 는 DB·Redis·API 가 있는 내부 서비스 네트워크에

연결하지 않고, 인터넷 출구가 없는 전용 네트워크(Docker internal)에 둔다. 외부 접속은 egress 전용 프록시 한 곳으로만 가능하며, 프록시가 연결 시점에 목적지 IP 를 다시 확인해 사설·예약·링크로컬(클라우드 메타데이터 169.254.169.254 포함)·내부 서비스 대역을 차단한다. SSRF 방어는 애플리케이션 검사(1 차)와 네트워크 차단(2 차)의 이중 구조이며, Worker 는 작업 수신과 결과 전달을 전용 수집 API 로만 하고 DB·큐 자격증명을 갖지 않는다.

증거 무결성: 증거 파일과 해시를 같은 저장소에 두면 저장소 권한을 가진 내부자가 둘 다 바꿀 수 있다. 이를 막기 위해 ① 각 증거 레코드에 직전 레코드 해시를 포함하는 추가 전용 해시 체인으로 중간 레코드의 수정·삭제를 드러내고, ② 레코드 해시에 HMAC-SHA256 서명을 붙이되 서명 키는 증거 저장소·DB 와 분리된 서명 서비스에만 두어 저장소 권한만으로는 유효한 서명을 만들 수 없게 하며, ③ 체인 헤드를 주기적으로 RFC 3161 타임스탬프 기관(TSA)에 서명받아 특정 시점 이후의 체인 재작성을 탐지한다(③은 외부 TSA 가용성에 따라 선택 적용). 조회·패키지 생성 시 해시·체인·서명을 모두 재검증한다.

2.8 행정안전부 sw 보안약점 관점의 시큐어코딩

분류	SafeTrace 위험 지점	적용 대책
입력데이터 검증 및 표현	URL, 검색조건, 수집 HTML, 파일명	Pydantic 스키마, 파라미터 바인딩, CSP, 서버 생성 파일명
보안기능	인증·인가, API 키, 자동화 계정	Argon2id, RBAC, 자동화 계정의 판정 확정 차단, 키 암호화/마스킹
시간 및 상태	중복 작업, 동시 판정	역등 키, 트랜잭션, 낙관적 잠금
에러처리	내부정보 노출, 실패 무시	일반화 오류 응답, 실패/시간 초과는 REVIEW_REQUIRED
코드오류	역직렬화, 자원 누수	JSON 만 허용, pickle 금지, context

		manager
캡슐화	디버그·민감 로그	운영 디버그 비활성화, 민감값 마스킹
API 오용	외부 API 무제한 호출, DNS 결과만 신뢰	호출 한도·타임아웃, 연결 시점 재검증

2.9 3 주 핵심 개발 계획과 잔여 기간 운영

운영요강상 사전 준비가 가능하므로 핵심 구성요소 일부를 미리 구현하고 설계를 확정한다. 개발경연(10/6~10/30) 중 자율 발굴을 포함한 ①→②→③ 핵심 흐름은 3 주 이내 완성을 목표로 하고, 마지막 기간은 공지 미션, 소스코드 진단 대비, 보안 개선과 발표 시연에 남긴다.

사전준비 (~10/5) 기구현 + 설계 확정	[기구현 완료] 브라우저 렌더링 녹화·실시간 조사 화면, AI 분석 의견 생성, Safe Browsing 조회, 공개 정상 사이트 평가 자료(D3) / [10/5 까지 구현] 파이프라인 실시간 UI(SSE 기반 단계별 대기·진행·완료·실패 상태, 발견·대기·조사·검토 필요 건수 표시), AI Decision Engine 1 차 버전(특징 추출, 규칙 기반 특징과 제로샷 분류 결합, 구조화 출력 스키마, UNKNOWN 정책), 조사 Worker 전용 네트워크(Docker internal)-egress 프록시 구성, 증거 해시 체인(직전 레코드 해시 연결·추가 전용 저장), D1-R 실데이터 수집 가동(2 주차까지 매일 수집), 기구현 브라우저 모듈에 URL·DNS·IP	기구현 기능 동작 확인, 실시간 UI 에 조사 흐름의 단계별 상태 표시, AI 엔진이 샘플 증거 입력에 유형·confidence·UNKNOWN 을 구조화 출력으로 반환, Worker 의 내부 서비스 직접 접속 차단 확인, 증거 레코드 수정·삭제 시 해시 체인·HMAC 서명 검증 실패 확인, 사설·예약 IP 로 향하는 리다이렉트 차단 확인, 개발환경 재현 가능.
--	--	---

	재검증·리다이렉트 추적 통합, 해시 체인에 분리된 서명 서비스의 HMAC 서명 추가 / [설계 확정] 요구사항·범위, 아키텍처·데이터 스키마·위협 모델, Candidate Discovery 정책·후보 스키마, KISA 데이터 적재 형식, 개발환경·저장소·CI, 평가셋·보안 시험 시나리오	Seed 소스·후보 큐·우선순위·탐색 한도와 핵심 인터페이스·스키마·위협 모델 확정
1 주차 (10/6~10/11)	API/DB/Queue, Candidate Discovery Queue(KISA 데이터·신고 URL Seed 적재, 정규화·중복 제거), 사전 구현 모듈(격리 브라우저·증거 저장·서명)과 큐의 종단 간 연결	Seed 1 건이 후보 큐→격리 조사→증거 저장까지 자동 완료. SSRF·내부망 접근·무한 리다이렉트 기본 시험 통과
2 주차 (10/12~10/18)	관찰 링크·리다이렉트 기반 후속 후보 재큐잉(허용목록 제외, 신규 등록·유사 도메인 가점 점수화, 깊이·후보 수·도메인 예산), 재큐잉 후보·관계 그래프를 실시간 UI 에 연결, AI Decision Engine 을 증거 저장소와 통합해 evidence_id 연결. 10/17 2 차 사전교육 참석(팀원 1 인 이상)	재큐잉·중복 차단·탐색 한도 준수 확인, 재큐잉 후보의 실시간 UI 반영, 증거→AI 분석→근거 링크 자동 연결. D1-R 수집 종료·스냅샷 동결, D1-S 동결
3 주차 (10/19~10/25)	Package Builder, Safe Browsing 조회 결과 패키지 통합, 담당자 검토/확정, 보고서 초안, D4 자율 발굴 평가, 통합 보안 시험	①→②→③ 전체 시연. 자동화 계정 판정 차단. 핵심 지표 측정

마무리 (10/26~10/30)	공지 미션 반영, SAST/SCA 조치, 사용자 평가, 시연·결과 보고	High 이상 보안 이슈 0 건 목표, 미션·결과물 제출 완료
----------------------	--	--

2.10 범위 통제와 실패 대비

위험	가능한 영향	통제 전략
AI 모델 품질이 기대보다 낮음	분석 신뢰도 저하	AI 를 최종 판정에 사용하지 않음. 규칙 특징과 UNKNOWN 으로 안전하게 보류하고, 성능은 있는 그대로 보고
실제 위협 데이터 확보량 부족	유형별 평가 표본 부족	확보 건수를 목표로 두지 않고 실제 건수를 그대로 보고. 표본이 적은 유형은 D1-S 결과와 구분 표기
자율 후보 탐색이 과도하게 확장	시간·자원 고갈, 불필요한 사이트 접근	정상 도메인 허용목록 제외, 신규 등록·유사 도메인 가점의 점수 기반 우선순위, visited 집합·중복 제거, 사건당 최대 깊이/후보 수/시간/도메인 예산
외부 API 장애/쿼터	패키지 생성 지연	Safe Browsing 조회 실패를 별도 상태로 기록하고 핵심 흐름은 계속 진행
2 인 팀 범위 과다	완성도 저하	VirusTotal·외부 자동 제출·다중 피드·대규모 분산 Worker 는 후속 단계로 고정
대회 중 미션 공지	일정 충돌	3 주차 중반부터 부가 기능 추가를 멈추고 미션을 우선 반영. 핵심

흐름은 2 주차 말까지 대부분 확보

2.11 평가 설계 – 기능 주장보다 재현 가능한 지표

실행가능성은 설명이 아니라 측정으로 입증한다. 요구사항→데이터→지표→통과 기준을 사전에 고정한다. 실제 위협 URL 접속은 D1-R 수집과 D4 Seed 조사로 한정하고, D1-R 은 격리 환경에서 1 회만 수집한 스냅샷을 Playwright HAR 재생으로 평가해 위협 사이트에 반복 접속하지 않으면서 결과를 재현한다. 회피 징후처럼 정답을 알아야 하는 항목은 D1-S 로 측정한다.

평가 데이터	구성	목적
D1-R 실제 위협 스냅샷	이용 조건을 확인한 공개 피싱·악성 URL 피드(예: OpenPhish 커뮤니티 피드, URLhaus), 공식 검색 API 결과, KISA 피싱사이트 URL 중 수집 시점에 접속 가능한 URL 만 격리 환경에서 1 회 수집(HAR·스크린샷·DOM)해 동결. 팀원 2 인 교차 라벨링, 주차·판단 불확실 페이지 제외. 확보 건수는 사전에 정하지 않고 실제 건수를 보고	실제 위협 대상 AI 유형 분석(R3)·정상 오인(R7)
D1-S 합성 시험 페이지	가상 피싱·사기·도박 의심 페이지 각 20 개 + 정상 대조 30 개. 지연 렌더링·다단계 리다이렉트 변형 포함	정답이 알려진 회피 징후 포착(R1), 실제 데이터가 부족한 사기·도박 유형 보완
D2 공격 시나리오	SSRF, DNS Rebinding, Worker 의 내부망·메타데이터 직접 접근, 무한 리다이렉트, 팝업/다운로드, 저장형 XSS, 대용량 DOM, 프롬프트 인젝션, 증거 파일·해시 동시 변조 등 15 종	도구 자체의 보안성

D3 공개 정상 사이트	공공·금융·쇼핑·택배 등 공개 화면 150 개 이상, 요청 간격 준수	대규모 정상 사이트 오탐 평가
D4 자율 후보 발굴	KISA 피싱사이트 URL·신고 URL 일부를 Seed 로 사용하고, 링크·리다이렉트로 서로 연결된 자체 시험 사이트군(Seed 10 개, 설계된 연관 후보 50 개, 사칭 대상 정상 사이트 링크 포함)에서 우선순위·재규잉·중복 제거·탐색 한도 검증	핵심 기능인 제한형 자율 탐색의 발굴력·안정성 확인
지표	목표	측정 방법
R1 동적 증거 포착	D1-S 의 자연 렌더링/리다이렉트 핵심 징후 90% 이상 포착	정적 HTML 기준선과 비교
R2 증거 무결성	증거 필수 메타데이터 포함률 100%, 변조 탐지 100%	파일 단독·파일+해시 동시·레코드 삭제 변조 주입 시험
R3 AI 분석 품질	유형별 Macro-F1 0.80 이상을 목표로 하되 confidence/UNKNOWN 도 함께 보고	피싱·악성은 D1-R 스냅샷을 HAR 재생으로 평가, 사기·도박은 D1-S 로 보완(학습·평가 템플릿 분리). 데이터 출처별 결과를 구분 표기, 모델 버전 고정
R4 설명가능성	AI 분석 결과의 evidence_links 제시율 100%	결과 JSON 자동 검사
R5 안전성	D2 공격 시나리오 15 종 모두 차단/격리	자동·수동 보안 시험

R6 처리시간	수동 사실 확인·자료 정리 대비 사건당 50% 이상 단축 목표	기준 절차(업무 PC 브라우저로 직접 접속 → 리다이렉트 수동 추적·화면 캡처 → Safe Browsing 수동 조회 → 문서 양식에 URL·캡처·근거 정리)와 비교, 팀 외 사용자 4~6 명 교차 평가
R7 정상 오인	D1-R·D1-S 정상 대조와 D3 정상 사이트에서 AI·자동화 계정에 의한 위협 판정 자동 확정 0 건	AI 는 자동 확정하지 않으므로 잘못된 강제 조치 방지 확인
R8 자율 발굴	D4 시험 사이트군에 설계된 연관 후보 50 개 중 40 개(80%) 이상 발굴, 허용목록 정상 도메인 재규잉·탐색 한도 초과·중복 조사 0 건	발견 경로·깊이 로그 자동 검사

R3 는 목표치이며, 미달하더라도 실제 측정값을 그대로 보고한다. SafeTrace 의 핵심
가치는 AI 정확도 하나가 아니라 "증거가 연결된 분석 + 안전한 보류 + 사람 확정"
구조에 있다.

3 활용방안 및 기대효과 (작성비중 : 30%)

3.1 주 활용처: 공공기관 신고·심의 업무

SafeTrace 의 직접 사용자는 불법·유해 사이트 신고를 접수하고 사실관계를 확인하는
공공기관 담당자다. 아래는 공개된 업무 절차를 기준으로 상정한 사용 기관과
단계이며, 실제 도입은 3.4 의 기관 협의·보안성 검토 이후를 전제로 한다. 시제품은
특정 기관의 실운영 시스템을 대체하지 않고 반복 업무를 안전하게 줄이는 보조

도구로 검증한다.

상정 사용 기관	업무 단계	SafeTrace 활용
KISA 118 상담센터·피싱 대응 부서	국민 신고·스미싱 확인서비스로 접수된 URL 의 사실 확인, 피싱 사이트 긴급 차단 조치 전 판단	신고 URL 일괄 격리 조사, 연관 사이트 자율 발굴, 차단 판단 근거가 담긴 사건 패키지
방송미디어통신심의위원회 (불법정보 심의)	도박·사기 등 불법정보 심의 안건 준비, 접속차단 시정요구 전 사실 확인	화면·이동 경로 증거와 AI 분석 의견을 담은 심의 자료 초안, 해시 체인·서명으로 증거 원본성 설명
경찰청 사이버수사 부서	사이버범죄 제보 검토, 수사 착수 전 증거 보존	수집 시각·서명이 붙은 증거 보존, 같은 운영 주체로 의심되는 도메인 묶음 제공

3.2 활용 시나리오

신고 URL 이나 KISA 피싱사이트 URL 이 들어오면 자율 발굴(허용목록

제외·우선순위화) → 격리 조사·증거 저장 → AI 분석 의견 → Safe Browsing 조회 → 검토 패키지 생성까지 자동으로 진행된다. 담당자는 실시간 화면에서 발견 후보와 진행 상황을 확인하고, 원본 증거를 검토한 뒤 최종 판정과 사유만 입력한다. 증거가 부족하면 UNKNOWN/REVIEW_REQUIRED 로 남기며, 최종 판정은 자동화 계정·AI 가 수행할 수 없다.

3.3 기대효과

기대효과	시제품 목표	공공 활용 의미
조사자 안전	업무 PC 에서 위험 페이지	악성 스크립트·리다이렉트 노출

	직접 열람 최소화	감소
업무 효율	사건당 사실 확인·자료 정리 시간 50% 이상 단축 목표	반복 업무 감소, 담당자는 판단에 집중
증거 신뢰성	수집 시각·SHA-256·해시 체인·HMAC 서명·감사로그 100% 기록	심의·감사 시 증거 출처와 변경 이력 설명 가능
설명가능성	AI 결과 evidence_links 제시율 100%	"왜 의심했는지"를 원본 증거로 검증 가능
부당 자동조치 방지	AI/자동화 계정의 판정 확정 권한 0	공공 업무 책임성 유지
확장성	기관별 양식·추가 평판 API 를 Connector 로 확장	기관 협의 후 단계적으로 적용 가능

3.4 실제 적용 로드맵

단계	범위	필요 조건
대회 시제품	KISA 공공데이터·실제 위협 스냅샷(D1-R)·모의 신고 데이터·자체 시험 페이지·공개 정상 사이트로 업무 흐름 검증	현재 기획 범위
기관 PoC	기관 제공 비식별/시험 데이터, 기관 양식에 맞춘 패키지 변환	기관 보안성 검토, 처리 근거·권한 협의
제한 운영	내부망 배치, 감사로그·보존 정책·권한 체계 고도화	개인정보·기록물·보안 정책 검토
확장	VirusTotal 등 추가 조회 Connector,	API 약관·비용·전송 정보

3.5 한계와 책임 있는 운영 원칙

- AI confidence 는 모델의 기술적 신뢰도이며 법적 위법성의 확률이 아니다.
- 불법 도박 등 법적 판단이 필요한 범주는 "의심 유형"으로만 표시한다.
- 외부 평판 DB 의 미등재는 정상(BENIGN)의 근거가 아니다.
- SafeTrace 의 자율 탐색은 공개 소스와 관찰된 연결 관계로 제한하며 인터넷 전체 무차별 크롤링, DNS 대입 탐색, 인증·CAPTCHA 우회, 결제·개인정보 입력, 취약점 공격을 수행하지 않는다.
- 실제 기관 적용 전에는 기관별 심의 절차, 제출 양식, 개인정보·기록물 처리 근거, 네트워크 보안 정책, 데이터 이용 권한을 별도로 확인한다.

3.6 대회 주제 및 트랙 c 적합성

SafeTrace 는 국민에게 피해를 줄 수 있는 위협 의심 사이트를 공공기관이 더 안전하고 일관되게 확인하도록 돕는 "공공 활용형 안전 SW"이며, 공공데이터포털의 KISA 피싱사이트 URL 데이터를 조사 시작점과 분석 참조 자료로 활용한다. 동시에 공격자가 통제하는 데이터를 직접 처리하기 때문에 SSRF, XSS, DNS Rebinding, 자원 고갈, 프롬프트 인젝션, 권한 우회 등 다양한 SW 보안약점을 실제 기능과 연결해 설계·시험할 수 있다.

핵심 메시지: SafeTrace 는 "인터넷 전체를 뒤지는 검색엔진"이 아니라, "공개 소스에서 시작해 관계 그래프를 따라 위협 의심 후보를 스스로 발굴하고, 공공기관 담당자가 근거를 더 안전하고 빠르게 확인해 판단하도록 돕는 보안 조사 자동화 시스템"이다.